

Security Vulnerability Fix Summary

Issue Identified: Session-based secure token storage vulnerability that could be exploited through session hijacking.

Root Cause: The original implementation stored sensitive authentication tokens in PHP sessions (`\$\_SESSION['secure\_token']` and `\$\_SESSION['sb\_login\_user\_id']`), making the authentication process vulnerable to session hijacking attacks.

Solution Implemented:

- **Eliminated Session-Based Token Storage**
 - **Removed:** Storage of secure tokens in `\$\_SESSION` variables
 - **Replaced:** With temporary token storage using WordPress transients with expiration
- **Enhanced Token Security**
 - **Token Generation:** 6-digit secure tokens using `openssl\_random\_pseudo\_bytes()`
 - **Storage Method:** Tokens stored in WordPress transients with 10-minute expiration
 - **Access Control:** Token keys stored in user meta for verification
- **Improved Authentication Flow**
 - **Firebase Integration:** Leveraged Firebase's built-in OTP system for secure phone verification
 - **ID Token Verification:** Backend verifies Firebase ID tokens instead of session data
 - **Phone Number Validation:** Ensures phone number ownership through Firebase verification
- **Security Enhancements**
 - **Rate Limiting:** Maintained existing rate limiting (5 attempts per 15 minutes)
 - **Data Sanitization:** All input data properly sanitized
 - **Nonce Verification:** WordPress nonce security maintained
 - **Automatic Cleanup:** Verification data automatically removed after successful login
- **Security Benefits Achieved**
 - **Session Hijacking Prevention :** No sensitive data stored in sessions
 - **Time-Limited Tokens :** 10-minute expiration prevents replay attacks

- Firebase Security : Leverages Firebase's secure OTP infrastructure
 - Phone Verification : Ensures phone number ownership through Firebase
 - Rate Limiting : Prevents brute force attacks
 - Data Cleanup : Automatic removal of sensitive data after use
- 7. Authentication Process
 - User enters phone number
 - System generates temporary secure token (6 digits)
 - Firebase sends OTP to user's phone
 - User enters OTP in Firebase verification modal
 - Firebase verifies OTP and provides ID token
 - Backend verifies ID token and phone number match
 - User logged in with automatic cleanup of temporary data

Result : The authentication system is now secure against session hijacking while maintaining the same user experience and leveraging Firebase's robust OTP system for secure phone verification.

This fix addresses the core security vulnerability by removing session-based token storage and implementing a more secure, time-limited token system with proper verification through Firebase's authentication infrastructure.